

Expert Survey on Patch Quality for Access Control Vulnerabilities in Web Applications

第1题：Case 1: AWCMS

Case 1 targets the AWCMS application developed in PHP, which suffers from a horizontal privilege escalation vulnerability. Its predefined authorization rules require regular users to only access their own personal data and administrators to access all members’ data, while forbidding unauthorized users from retrieving other users’ information by tampering with member identifiers; please refer to the attached code comparison figures showing the code before and after vulnerability remediation.

member.php(before patch)	member.php(after patch)
<pre>... include ("includes/window_top.php"); \$gid = \$_GET['id']; ?> <title><?php print \$title; ?></title> ...</pre>	<pre>... include ("includes/window_top.php"); \$gid = \$_GET['id']; if (\$member_level != 'admin' && \$member != \$gid) { print '<meta http-equiv="refresh" content="0;URL=login.php">'; exit; } ?> <title><?php print \$title; ?></title> ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?
[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	3	16.67%
4.Agree	10	55.56%
5.Strongly Agree	5	27.78%
本题有效填写人次	18	

第2题：Case 2: Phpoll

Case 2 focuses on the patch for Phpoll, a program written in PHP that contains a vertical privilege escalation vulnerability. The expected authorization logic specifies that only users authenticated via the application’ s native administrator verification mechanism are allowed to access pages related to vote management, and unauthenticated users should be blocked from directly accessing or modifying back-end voting data; please see the code comparison figures illustrating the source code before and after the vulnerability repair below.

```
admin/modifica_votanti.php(before patch)
...
mysql_select_db($phpoll_database, $phpoll_db)
or die ("Errore nella connessione al database ".$phpoll_database);

// QUERY per MySQL
$query_voti = "SELECT * FROM ".$tab_voti.";";
...
```

```
admin/modifica_votanti.php(after patch)
...
mysql_select_db($phpoll_database, $phpoll_db)
or die ("Errore nella connessione al database ".$phpoll_database);
if(!isset($_COOKIE['string_cook_login']) && isset($_COOKIE['string_cook_password'])) {
    die("Accesso non autorizzato.");
}
// QUERY per MySQL
$query_voti = "SELECT * FROM ".$tab_voti.";";
...
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	1	5.56%
4.Agree	9	50%
5.Strongly Agree	8	44.44%
本题有效填写人次	18	

第3题：Case 3: Phpns

Case 3 covers the repair patch for Phpns, a PHP-based application with a vertical privilege escalation vulnerability, where the intended authorization rule dictates that users without text editing permissions are prohibited from deleting comments; please refer to the code comparison figures displaying the code before and after the vulnerability fix below.

article.php(before patch)	article.php(after patch)
<pre>... foreach(\$items as \$key=>\$value) { \$items_f = \$items_f."\$key,"; } //remove last comma in list for SQL \$items_f = substr_replace(\$items_f,"",-1); //delete the items in 'articles' delete('comments',\$items_f); ...</pre>	<pre>... foreach(\$items as \$key=>\$value) { \$items_f = \$items_f."\$key,"; } //remove last comma in list for SQL \$items_f = substr_replace(\$items_f,"",-1); //delete the items in 'articles' if (\$GLOBALS['rank'][14] == 1) { delete('comments', \$items_f); } else { header("Location: index.php?do=nopermission"); die(); } ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%

3.Neutral	2	11.11%
4.Agree	9	50%
5.Strongly Agree	7	38.89%
本题有效填写人次	18	

第4题：Case 4: Bwapp

Case 4 involves the repair patch for the BWAPP application coded in PHP, which exists a vertical privilege escalation vulnerability, and its expected authorization rule is that unlogged-in users shall be rejected access or redirected; please refer to the code comparison figures showing the code before and after vulnerability remediation below.

backdoor.php(before patch)

```
<?php
if(isset($_REQUEST["upload"])){
    $dir=$_REQUEST["uploadDir"];
    if(PHP_VERSION<'4.1.0'){
        $file=$_HTTP_POST_FILES["file"]["name"];
        @move_uploaded_file($_HTTP_POST_FILES["file"]["tmp_name"],$dir."/".$file) or die();
    }else{
        ...
    }
}
```

backdoor.php(after patch)

```
<?php
if(isset($_REQUEST["upload"])){
    if(!(isset($_SESSION["login"]) && $_SESSION["login"] == true)){
        header("Location: login.php");
        exit;
    }
    $dir=$_REQUEST["uploadDir"];
    if(PHP_VERSION<'4.1.0'){
        $file=$_HTTP_POST_FILES["file"]["name"];
        @move_uploaded_file($_HTTP_POST_FILES["file"]["tmp_name"],$dir."/".$file) or die();
    }else{
        ...
    }
}
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	4	22.22%
4.Agree	7	38.89%
5.Strongly Agree	7	38.89%

第5题：Case 5: DVWA

Case 5 presents the repair patch for DVWA, a PHP-written application affected by a vertical privilege escalation vulnerability. The expected authorization rule requires that unauthenticated users are prohibited from directly accessing configuration or initialization functions; please refer to the code comparison figures showing the source code before and after the vulnerability fix below.

<pre>instructions.php(before patch) ... \$page = dvwaPageNewGrab(); \$page['title'] = 'Instructions' . \$page['title_separator'].\$page['title']; \$page['page_id'] = 'instructions'; ...</pre>	<pre>instructions.php(after patch) ... dvwaPageStartup(array('authenticated')); \$page = dvwaPageNewGrab(); \$page['title'] = 'Instructions' . \$page['title_separator'].\$page['title']; \$page['page_id'] = 'instructions'; ...</pre>
--	--

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	3	16.67%
4.Agree	6	33.33%
5.Strongly Agree	9	50%
本题有效填写人次	18	

第6题：Case 6: SCARF

Case 6 describes the patch for SCARF, a PHP application vulnerable to vertical privilege escalation, and the expected authorization constraint is that access to this page should be restricted exclusively to administrators; please refer to the figures comparing the code before and after vulnerability remediation shown below.

<pre>generaloptions.php(before patch) <?php include_once("header.php"); if (isset(\$_POST['submit'])) { foreach (\$_POST as \$name => \$value) { \$name = mysql_real_escape_string(\$name); \$name = str_replace("_", " ", \$name); \$value = mysql_real_escape_string(\$value); query("UPDATE options SET value='\$value' WHERE name='\$name'"); }... }</pre>	<pre>generaloptions.php(after patch) <?php include_once("header.php"); require_admin(); if (isset(\$_POST['submit'])) { foreach (\$_POST as \$name => \$value) { \$name = mysql_real_escape_string(\$name); \$name = str_replace("_", " ", \$name); \$value = mysql_real_escape_string(\$value); query("UPDATE options SET value='\$value' WHERE name='\$name'"); }... }</pre>
---	---

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	3	16.67%
4.Agree	9	50%
5.Strongly Agree	6	33.33%
本题有效填写人次	18	

第7题：Case 7: EventsLister

Case 7 introduces the repair patch for EventsLister, a PHP application suffering from a vertical privilege escalation vulnerability, whose expected authorization rule restricts access to the add-user page solely to users who have completed backend login authentication; please refer to the figures comparing the code before and after vulnerability remediation provided below.

user_add.php(before patch)

```
...
mysqli_select_db($con, $dbname) or die( "Unable to select database");

$query = "INSERT INTO admin VALUES ('','$uname', '$pwd')";
...
```

user_add.php(after patch)

```
...
if (!isset($_SESSION['validUser']) || ($_SESSION['validUser'] != true)) {
    header('Location: login.php');
    exit;
}
mysqli_select_db($con, $dbname) or die( "Unable to select database");

$query = "INSERT INTO admin VALUES ('','$uname', '$pwd')";
...
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	2	11.11%
4.Agree	6	33.33%
5.Strongly Agree	10	55.56%
本题有效填写人次	18	

第8题：Case 8: Mybb

Case 8 discusses the repair patch for Mybb, a PHP application with a vertical privilege escalation vulnerability. Its expected authorization rules require users to complete password verification for password-protected forums before subscribing, while

administrator permissions are managed in accordance with the application’s original built-in logic; please refer to the figures comparing the code before and after vulnerability remediation below.

usercp2.php(before patch)	usercp2.php(after patch)
<pre>... add_subscribed_forum(\$forum['fid']); if(\$server_http_referer) { \$url = \$server_http_referer; } else { \$url = "index.php"; } ...</pre>	<pre>... if(\$forum['password'] && \$mybb->usergroup['can_cp'] != 1) { check_forum_password(\$forum['fid']); } add_subscribed_forum(\$forum['fid']); if(\$server_http_referer) { \$url = \$server_http_referer; } else { \$url = "index.php"; } ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	4	22.22%
4.Agree	6	33.33%
5.Strongly Agree	8	44.44%
本题有效填写人次	18	

第9题：Case 9: Wackopicko

Case 9 covers the repair patch for Wackopicko, a PHP application containing a horizontal privilege escalation vulnerability, and its expected authorization rules specify that regular users can only access their own user profiles and must not view other users’ profiles by tampering with the userid parameter; please refer to the figures comparing the code before and after vulnerability remediation below.

users/view.php(before patch)	users/view.php(after patch)
<pre><?php ... \$user = Users::get_user(\$_GET['userid']); if (!\$user) { error_404(); } \$pictures = Pictures::get_all_pictures_by_user(\$_GET['userid']); ?></pre>	<pre><?php ... \$user = Users::get_user(\$_GET['userid']); if (!\$user) { error_404(); } if (isset(\$_SESSION['userid']) && \$_SESSION['userid'] == \$_GET['userid']) { \$pictures = Pictures::get_all_pictures_by_user(\$_GET['userid']); } else { http_redirect(Users::\$LOGIN_URL); } ?></pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	4	22.22%
4.Agree	10	55.56%
5.Strongly Agree	4	22.22%
本题有效填写人次	18	

第10题：Case 10: Jspblog

Case 10 illustrates the repair patch for Jspblog, an application developed with Java/JSP that has a vertical privilege escalation vulnerability. The expected authorization rule states that only logged-in backend users are authorized to access news editing and publishing pages, while unauthenticated users should either be redirected to the login page or denied access; please refer to the figures comparing the code before and after vulnerability remediation below.

editnews2.jsp(before patch)	editnews2.jsp(after patch)
<pre>... Connection Conn = DriverManager.getConnection(connString); java.sql.Statement SQLStatement = Conn.createStatement(); String Query = "UPDATE news set body = '" + body + "'"; ...</pre>	<pre>... if (session.getAttribute("isLoggedIn") == null) { response.sendRedirect("login.jsp"); return; } Connection Conn = DriverManager.getConnection(connString); java.sql.Statement SQLStatement = Conn.createStatement(); String Query = "UPDATE news set body = '" + body + "'"; ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	1	5.56%
4.Agree	5	27.78%
5.Strongly Agree	12	66.67%
本题有效填写人次	18	

第11题：Case 11: JsForum

Case 11 presents the repair patch for JsForum, a Java application affected by a vertical privilege escalation vulnerability, and its expected authorization rule requires that only administrator users are permitted to publish posts; please refer to the figures comparing the code before and after vulnerability remediation shown below.

AddForum.java(before patch)	AddForum.java(after patch)
<pre>... String forum_info = request.getParameter("forum_info"); forum_info = Filter.filterAll(forum_info); db.connect(); db.query("INSERT INTO forum_forums(forum_id,title,forum_info) "+ "VALUES('"+ forum_id + "'','"+ title + "'','"+ forum_info + "')"); db.close(); ...</pre>	<pre>... String forum_info = request.getParameter("forum_info"); forum_info = Filter.filterAll(forum_info); db.connect(); if(sessionType.equals("Admin")){ db.query("INSERT INTO forum_forums(forum_id,title,forum_info) "+ "VALUES('"+ forum_id + "'','"+ title + "'','"+ forum_info + "')"); }else{ response.sendRedirect("index.jsp"); } db.close(); ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	2	11.11%
4.Agree	6	33.33%
5.Strongly Agree	10	55.56%
本题有效填写人次	18	

第12题：Case 12: jwablogger

Case 12 describes the repair patch for jwablogger, a Java application vulnerable to vertical privilege escalation, with its expected authorization rule specifying that unauthorized users are forbidden from directly accessing invisible blog entries; please refer to the figures comparing the code before and after vulnerability remediation below.

```
webApp/Blogger.java(before patch)
...
public String processViewEntry(ServerInterface serverInterface) throws JWebAppException, JPersistException
{
    WebAppInterface.viewEntry((BlogManager)serverInterface.getServletContext().getAttribute("blogManager"),
        serverInterface.getServletRequest(), serverInterface.getPathArguments(),
        getControl(serverInterface), serverInterface.isUserInRole("administrator"));

    return "/blogger/template";
}
...

webApp/Blogger.java(after patch)
...
public String processViewEntry(ServerInterface serverInterface) throws JWebAppException, JPersistException
{
    if (serverInterface.getRemoteUser() == null)
        return "/blogger/entries";
    WebAppInterface.viewEntry((BlogManager)serverInterface.getServletContext().getAttribute("blogManager"),
        serverInterface.getServletRequest(), serverInterface.getPathArguments(),
        getControl(serverInterface), serverInterface.isUserInRole("administrator"));

    return "/blogger/template";
}
...
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	0	0%
4.Agree	8	44.44%
5.Strongly Agree	10	55.56%
本题有效填写人次	18	

第13题： Case 13: DjangoBlog

Case 13 introduces the repair patch for DjangoBlog, a Python-based application plagued by a vertical privilege escalation vulnerability. The expected authorization rule mandates that unlogged-in users cannot view unpublished articles by directly accessing relevant URLs; please refer to the figures comparing the code before and after vulnerability remediation below.

```
blog/views.py(before patch)
...
class PostDetail(generic.DetailView):
    model = Post
    template_name = 'post_detail.html'
...
```

```
blog/views.py(after patch)
...
class PostDetail(generic.DetailView):
    model = Post
    template_name = 'post_detail.html'

    def get_object(self, queryset=None):
        obj = super().get_object(queryset)

        if obj.status == 0 and not self.request.user.is_staff:
            raise Http404()

        return obj
...
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	2	11.11%
4.Agree	9	50%
5.Strongly Agree	7	38.89%
本题有效填写人次	18	

第14题：Case 14: django_lms

Case 14 covers the repair patch for django_lms, a Python application with a vertical privilege escalation vulnerability. Its expected authorization rule dictates that administrative functions such as creating new courses and events are accessible exclusively to administrators, and regular logged-in users must not perform administrative operations by directly requesting hidden entry points; please refer to the figures comparing the code before and after vulnerability remediation below.

```
app/views.py(before patch)
...
@login_required
def post_add(request):
    if request.method == 'POST':
        form = NewsAndEventsForm(request.POST)

    ...
    return render(request, 'app/post_add.html', {
        'title': 'Add Post | DjangoSMS',
        'form': form,
    })
...
```

```
app/views.py(after patch)
...
@login_required
@admin_required
def post_add(request):
    if request.method == 'POST':
        form = NewsAndEventsForm(request.POST)

    ...
    return render(request, 'app/post_add.html', {
        'title': 'Add Post | DjangoSMS',
        'form': form,
    })
...
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
----	----	----

1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	2	11.11%
4.Agree	7	38.89%
5.Strongly Agree	9	50%
本题有效填写人次	18	

第15题：Case 15: BBS_Pro

Case 15 discusses the repair patch for BBS_Pro, a Python application suffering from a vertical privilege escalation vulnerability, whose expected authorization rule restricts access to and submission of forum posting functions exclusively to logged-in users; please refer to the figures comparing the code before and after vulnerability remediation below.

app01/views.py(before patch)	app01/views.py(after patch)
<pre>... bbs_category = request.POST.get('bbs_category') models.BBS.objects.create(title=request.POST.get('title'), category=models.Category.objects.get(name=bbs_category), content=request.POST.get('content'), author=models.BBS_user.objects.get(user_username='root'), modify_date=datetime.datetime.now()) ...</pre>	<pre>... bbs_category = request.POST.get('bbs_category') if not request.user.is_staff: return HttpResponseRedirect('/login/') models.BBS.objects.create(title=request.POST.get('title'), category=models.Category.objects.get(name=bbs_category), content=request.POST.get('content'), author=models.BBS_user.objects.get(user_username='root'), modify_date=datetime.datetime.now()) ...</pre>

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	4	22.22%
4.Agree	4	22.22%
5.Strongly Agree	10	55.56%
本题有效填写人次	18	

第16题：Case 16: orangeforum

Case 16 presents the repair patch for orangeforum, a Go application affected by a horizontal privilege escalation vulnerability. Its expected authorization rules stipulate that regular users may only edit or delete their own comments, administrator and moderator

permissions are handled following the application’s native logic, and ordinary users are prohibited from manipulating other users’ comments by tampering with comment identifiers; please refer to the figures comparing the code before and after vulnerability remediation below.

views/comments.go(before patch)

```
else if action == "Update" {
    models.UpdateCommentByID(comment.CommentID, content,
isSticky)
    ...
    return
}
```

views/comments.go(after patch)

```
else if action == "Update" {
    if user.UserID != comment.UserID && !user.IsSuperAdmin {
        models.UpdateCommentByID(comment.CommentID, content,
isSticky)
    }else{
        http.Error(w, http.StatusText(http.StatusForbidden),
http.StatusForbidden)
        return
    }
    ...
    return
}
```

To what extent do you agree that the repair patch demonstrates satisfactory overall quality?

[单选题]

选项	小计	比例
1.Strongly Disagree	0	0%
2.Disagree	0	0%
3.Neutral	0	0%
4.Agree	10	55.56%
5.Strongly Agree	8	44.44%
本题有效填写人次	18	